# Aegis-SOC: Problem Statement — Indian-Origin Cloud-Only SIEM for SMEs

Rudra Pratap

## Contents

**Problem Statement — Indian-Origin, Cloud-Only SIEM for SMEs** **1**
1. One line . . . 1
2. Who exactly (be specific — “SMEs” is too broad) . . . 1
3. The four pains (in the order they actually hurt) . . . 2
4. Why now: the compliance clock (the strongest argument) . . . 2
5. What “Indian-origin” must concretely mean . . . 3
6. What we have built vs what the platform needs . . . 3
7. Slide-ready wording . . . 3
8. Questions this framing invites — and the answers . . . 4
9. Claims to avoid . . . 4

# Problem Statement — Indian-Origin, Cloud-Only SIEM for SMEs

> Regulatory references below are for positioning in a presentation. **Verify exact clauses before quoting them in a written submission**, and treat this as engineering context, not legal advice.

---

## 1. One line

> **Indian SMEs are legally required to detect, log and report security incidents — but existing SIEMs are priced and sized for enterprises, and the affordable cloud-native ones are foreign-hosted. We are building an Indian-origin, real-time SIEM for organisations that run entirely on cloud.**

## 2. Who exactly (be specific — “SMEs” is too broad)

| Attribute | Target segment |
|---|---|
| Size | 20–250 employees; 1–3 IT staff, no dedicated SOC, no 24×7 analyst |
| Infrastructure | **Cloud-only** — AWS / Azure / GCP, no on-prem data centre |
| Data | Customer PII, payment data, employee records — i.e. DPDP-relevant |
| Pressure | Customer security questionnaires, DPDP readiness, an incident that already happened |
| Budget reality | Cannot justify ₹10–25 lakh/year enterprise SIEM; can justify ₹10–50k/month |

The "cloud-only" constraint is the wedge: they have no appliance to rack, no collector VM to maintain, and no staff to tune a legacy SIEM. Everything must arrive as a service.

## 3. The four pains (in the order they actually hurt)

1. **Integration effort.** A SIEM is not a product you install — it is connectors, parsers, rule tuning and dashboards. For a 2-person IT team this is months of work they will never be given.
2. **Skill gap.** Writing detection rules, triaging alerts and deciding response requires a security analyst. SMEs do not have one, and cannot hire one at Indian market rates.
3. **Cost.** Enterprise SIEM licensing is priced per GB ingested and per seat. Cloud egress and retention charges stack on top. The result is a platform priced for a bank, sold to a 60-person company.
4. **Compliance is not optional.** This is the part most pitches miss — see §4.

## 4. Why now: the compliance clock (the strongest argument)

Two Indian instruments convert "we should have a SIEM" into "we are required to keep and produce this evidence":

| Obligation | Instrument | What it means operationally |
|---|---|---|
| **180-day log retention within Indian jurisdiction** | CERT-In Directions, 28 April 2022 | Logs must be retained for 180 days **in India**. A 30-day retention policy is a compliance gap — and makes forensic reconstruction impossible |
| **6-hour incident reporting** | CERT-In Directions, 28 April 2022 | Reportable incidents must reach CERT-In within six hours of *noticing*. Detection latency is now a legal exposure, not just an operational one |
| NTP sync, designated point of contact | CERT-In Directions, 28 April 2022 | Basic hygiene that is auditable |
| **Security safeguards + breach notification** | DPDP Act 2023, s.8(3) and s.8(6) / Rule 7 | Safeguards to prevent breach; notify the Board and affected Data Principals, with a detailed report inside 72 hours |
| **Penalty maxima** | DPDP Act 2023 | Up to **₹250 crore** for failure of reasonable security safeguards; up to **₹200 crore** for breach-notification failure |
| **Timeline** | DPDP Rules 2025 (notified 13 Nov 2025) | Full substantive compliance from **13 May 2027** |

The commercial insight: a cloud-only SME today has **no affordable way to hold 180 days of searchable logs inside India with detection on top**. Managed logging gets them storage; it does not get them detection, triage, or a six-hour reporting workflow. That gap is the product.

**Framing sentence for the presentation:**

> "CERT-In already requires 180 days of logs retained in India and reporting within six hours. DPDP adds breach notification with penalties up to ₹250 crore from May 2027. An SME with two IT staff cannot meet either obligation with an enterprise SIEM they cannot afford, or with a foreign SaaS they cannot audit. That is the gap."

## 5. What "Indian-origin" must concretely mean

Otherwise it is a slogan. Four testable commitments:

1. **Data residency** — logs and alerts stored in an Indian region, retained 180+ days, exportable for CERT-In/DPDP evidence.
2. **INR pricing, predictable** — per-organisation tiers, not per-GB billing that punishes an incident (the moment you most need logs is the moment volume spikes).
3. **Indian regulatory templates built in** — CERT-In incident report, DPDP breach intimation, evidence export with chain-of-custody metadata.
4. **Local support and local rule content** — Indian attack patterns, Indian SaaS stack (Zoho, Razorpay, Paytm, Tally integrations), support in IST.

## 6. What we have built vs what the platform needs

Be precise here; this is where overclaiming gets punished.

| Capability | Current artifact | Platform requirement |
|---|---|---|
| Detection | 13 ATT&CK-mapped rules + anomaly baseline, one host | Hundreds of rules, cloud-native log sources (CloudTrail, VPC flow, Azure AD, GCP audit) |
| Triage | LLM verdict with schema validation + injection defences | Same, plus per-tenant tuning and analyst feedback loop |
| Response | Deterministic policy gate, simulated containment | Real integrations: cloud IAM revoke, WAF/SG block, ticketing |
| Storage | SQLite / Firestore option | 180-day hot+warm search, in-India region, per-tenant isolation |
| Multi-tenancy | **None** — single tenant | Tenant isolation, per-tenant keys, RBAC, audit log |
| Connectors | HTTP `/ingest` only | Agent + cloud-native pull; 20+ sources to be credible |
| Compliance output | None | CERT-In report, DPDP breach pack, evidence export |

**The honest sentence for the viva:**

> "What we built is the detection, triage and response core of that platform — one container, one host, measured end to end. What we have not built is the multi-tenant platform around it: connectors, 180-day retention in an Indian region, and per-tenant isolation. Those are the next twelve months, not this semester."

That distinction is defensible. Claiming the prototype *is* a SIEM is not.

## 7. Slide-ready wording

**Replace the "design question" line on the problem slide with:**

> "Indian SMEs must retain 180 days of logs in India and report incidents in 6 hours — with two IT staff, no analyst, and no budget for enterprise SIEM."

**Add a roadmap slide (or replace "future work") titled "From prototype to platform":**

- Multi-tenant isolation + per-tenant encryption keys
- Cloud-native connectors: CloudTrail, VPC flow, Azure AD, GCP audit, Zoho/Razorpay
- 180-day retention in an Indian region, with TTL and export
- CERT-In and DPDP breach-report generation from the alert record
- INR-tiered pricing with no per-GB penalty during an incident

## 8. Questions this framing invites — and the answers

| Question | Answer |
|---|---|
| “Why not just use Wazuh/ELK?” | They are credible and free, and they still need a host, an analyst and tuning — the integration effort is the barrier, not the licence. Also: retention must sit in India, and someone must operate it at 2 a.m. |
| “Why not Sentinel/QRadar cloud?” | Priced per GB and per seat in USD; for an Indian SME the bill scales with the incident. Data residency and support timezone are secondary objections on top. |
| “Isn’t LLM triage risky?” | That is precisely what we measured: 58% hijack undefended → 0% with defences, and the model cannot authorise containment. |
| “How is this Indian-origin beyond branding?” | Residency, INR pricing, Indian regulatory templates, Indian log sources, IST support. §5 lists all five as commitments. |
| “Is 13 rules a SIEM?” | No. It is the detection core of one, measured honestly — 13/13 on our corpus, 1/6 on evasions. The platform needs breadth; we built and validated the engine. |

## 9. Claims to avoid

- “Real-time” without a number: state detection latency (ours: sub-second ingest→alert on one host).
- “AI-powered” as the headline: the differentiator is the **policy gate**, not the model.
- “Compliant with CERT-In / DPDP”: the product can *support* compliance; only an assessor certifies.
- “Enterprise-grade”, “military-grade”, “zero-day detection” — all indefensible in a viva.